COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.3 · Change Management

Mestre CyberSec · **Lesson 1.3 — Change Management** (11:22) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Mudança em produção com segurança: documentar a requisição de mudança (RFC), checar risco, aprovar (CAB — Change Advisory Board), testar em ambiente isolado, agendar janela, ter plano de ROLLBACK, avisar afetados; executar, verificar, documentar. Emergency change: menos processo,

💡 Key Exam Highlights & Critical Concepts

- Rollback plan: o que fazer se der errado — SEM isso, não aprova
- Emergency change: CAB rápido, ainda documentado
- Todo change passa por ambiente de TESTE antes de produção

🎯 Exam Tips & Typical CompTIA Scenarios

- 'requires rollback plan and testing before deployment' = change management
- 'emergency change bypasses some approvals' = ainda precisa de documentação

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.3 — Change Management)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Change Management (CM)

A formal process for requesting, reviewing, approving, testing, and documenting any modification to production systems to minimize disruption and security risk.

⚠️ ***Exam Trap:*** *Trigger phrase 'requires rollback plan and testing before deployment' = Change Management. Sempre cite o processo formal completo (RFC → análise de risco → teste → aprovação → execução).*

• Request for Change (RFC)

A formal proposal document submitted to initiate any change in production, describing what will change, why, and its associated risks and rollback procedures.

⚠️ ***Exam Trap:*** *Toda mudança em produção COMEÇA com um RFC. Sem documentação formal, não existe mudança gerenciada válida.*

• Change Advisory Board (CAB)

A group of stakeholders who review and approve/reject proposed changes, assessing risk, impact, and resource requirements before allowing deployment.

⚠️ ***Exam Trap:*** *CAB approval = mandatory gate in change management. Em emergências, há um 'Emergency CAB' ou aprovação acelerada, mas NUNCA eliminada totalmente.*

• Rollback Plan (N/A)

A documented procedure to revert a system to its previous working state if a change causes failure or unintended consequences.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'no rollback plan' = change NÃO será aprovada. É a razão #1 de reprovação em perguntas de change management.*

• Emergency Change (N/A)

A change required to restore service or address critical security issues that bypasses the normal CAB approval timeline while still requiring documentation.

⚠️ ***Exam Trap:*** *'Emergency change bypasses some approvals' = ainda precisa de documentação pós-fato e aprovação retroativa. Nunca é totalmente sem processo.*

• Sandbox / Test Environment (N/A)

An isolated, non-production environment where changes are deployed and validated before being promoted to production systems.

⚠️ ***Exam Trap:*** *Toda mudança DEVE passar por ambiente de teste antes de produção. Pular essa etapa é violação direta do change management.*

• Change Window (N/A)

A pre-approved scheduled timeframe (typically low-usage hours) during which changes to production systems may be deployed.

⚠️ ***Exam Trap:*** *Mudanças em produção fora da change window = violação. Janelas existem para minimizar impacto ao usuário e permitir resposta rápida a incidentes.*

• Impact Analysis / Risk Assessment (N/A)

The evaluation of potential consequences, affected systems, and security risks associated with a proposed change before approval.

⚠️ ***Exam Trap:*** *Sem análise de risco documentada, o CAB NÃO deve aprovar a mudança. É insumo obrigatório do RFC.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services company's system administrator needs to apply a vendor security patch to the production authentication server. The patch has not been deployed anywhere else. According to change management best practices, which action should the administrator take first?

A) Submit a request for change and complete an impact and risk assessment.

B) Apply the patch immediately because it is security-related.

C) Notify customers after the patch is installed and verified.

D) Create a post-implementation report for the Change Advisory Board to review later.

QUESTION 2 · EXAM SCENARIO

The Change Advisory Board is reviewing a request to open a new inbound firewall rule from the internet to a payment application. Which information is most important for the CAB to decide whether to approve the change?

A) The number of firewall vendors used by the organization.

B) The seniority of the engineer who submitted the request.

C) The department budget code associated with the change.

D) The documented business justification, risk and impact analysis, and rollback plan.

QUESTION 3 · EXAM SCENARIO

After CAB approval, a team must validate new web server configuration changes before they reach production. Which environment should be used to reduce the risk of service disruption?

A) The production environment during off-peak hours.

B) An isolated sandbox or staging environment that mirrors production.

C) A single production node temporarily removed from the load balancer.

D) The disaster recovery site while users are active.

QUESTION 4 · EXAM SCENARIO

A network team plans to upgrade firmware on core switches during a maintenance window. The upgrade has a known risk of causing routing instability. Which control best prepares the team to recover quickly if the upgrade fails?

A) A signed acceptable use policy from the network team.

B) A longer change window with no user notification.

C) A documented rollback plan and current backup of switch configurations.

D) A second change request submitted after the upgrade.

QUESTION 5 · EXAM SCENARIO

An administrator completes an approved change to a production API gateway. Monitoring shows normal CPU usage, but the business team reports that a critical endpoint returns errors. What should the administrator do next as part of change management?

A) Close the change ticket because the scheduled window has ended.

B) Verify the change against success criteria and document the issue; if needed, execute rollback.

C) Immediately delete the change record to avoid audit findings.

D) Wait until the next CAB meeting to investigate.

QUESTION 6 · EXAM SCENARIO

A zero-day vulnerability is being actively exploited against the company's public-facing VPN. The vendor releases an emergency patch outside the normal maintenance schedule. What is the most appropriate change management approach?

A) Wait for the next monthly CAB meeting to review the patch.

B) Deploy the patch without any approval or documentation because it is urgent.

C) Use the emergency change process with expedited approval, then document and review afterward.

D) Apply the patch to production only after a full 30-day pilot in a sandbox.

QUESTION 7 · EXAM SCENARIO

A company schedules a change to update DNS records for its customer portal during a weekend maintenance window. Which action best satisfies the communication requirement of the change management process?

A) Send advance notification of the schedule, expected impact, and support contact to affected users and teams.

B) Post the change details only in the engineering team's private chat after completion.

C) Avoid notification to prevent attackers from learning about the maintenance.

D) Tell the CAB only, since end users do not need to know about DNS changes.

QUESTION 8 · EXAM SCENARIO

A database administrator proposes a schema change to a production ERP database. The CAB requires a documented method to restore the database to its previous state if the change causes data corruption. Which artifact should the DBA provide?

A) A service level agreement (SLA).

B) A rollback plan.

C) A memorandum of understanding (MOU).

D) An incident response policy.

QUESTION 9 · EXAM SCENARIO

A company must perform a major upgrade of its production customer relationship management (CRM) platform. The change is approved for Sunday from 01:00 to 05:00, when usage is lowest. Which change management concept does this schedule primarily represent?

A) Emergency change approval.

B) Separation of duties.

C) Change window.

D) Least privilege.

QUESTION 10 · EXAM SCENARIO

A production change to a load balancer caused an outage. The team successfully executed the rollback plan and restored service. According to change management best practices, what should happen next?

A) Reapply the same change immediately without analysis.

B) Close the ticket because rollback restored service.

C) Conduct a post-implementation review and document lessons learned.

D) Transfer the change request to the incident response team and take no further action.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Submit a request for change and complete an impact and risk assessment.
The first step is to formally document the change and assess its impact and risk so the CAB can make an informed decision. Security-related patches do not automatically bypass change control unless they qualify for the emergency change process. Applying first, notifying after, or documenting only afterward skips required approval, testing, and risk analysis.

Question 2: Option D — The documented business justification, risk and impact analysis, and rollback plan.
CAB decisions should be based on business need, risk, impact, and the ability to recover if the change fails. Vendor count, engineer seniority, and budget codes do not provide enough security or operational justification for approving a high-risk firewall rule.

Question 3: Option B — An isolated sandbox or staging environment that mirrors production.
An isolated sandbox or staging environment allows testing without affecting production users or data. Testing in production, even during off-peak hours or on one node, still introduces risk to live services. The disaster recovery site is for continuity, not routine change validation.

Question 4: Option C — A documented rollback plan and current backup of switch configurations.
A rollback plan with current configuration backups gives the team a tested way to restore the prior state quickly if the firmware upgrade causes problems. A longer window or a later change request does not restore service, and an acceptable use policy is unrelated to technical recovery.

Question 5: Option B — Verify the change against success criteria and document the issue; if needed, execute rollback.
After a change, the team must verify that success criteria are met and document the outcome. If verification fails, the rollback plan should be followed. Closing the ticket, deleting records, or waiting for the next CAB meeting ignores the failed change and delays recovery.

Question 6: Option C — Use the emergency change process with expedited approval, then document and review afterward.
Emergency changes allow expedited approval and implementation to address urgent risk, but they still require documentation and a post-implementation review. Waiting for a monthly CAB or requiring a 30-day pilot leaves the organization exposed. Skipping all approval and documentation creates accountability and audit gaps.

Question 7: Option A — Send advance notification of the schedule, expected impact, and support contact to affected users and teams.
Affected stakeholders should receive advance notice about schedule, potential impact, and how to get support. Informing only engineers after the fact, hiding the maintenance, or limiting communication to the CAB does not meet user and business communication needs.

Question 8: Option B — A rollback plan.
A rollback plan documents how to revert the change and restore the prior state if implementation fails. An SLA defines service expectations, an MOU records an agreement between parties, and an incident response policy guides handling of security incidents; none specifically provides the backout procedure for this change.

Question 9: Option C — Change window.
A change window is a scheduled period chosen to reduce business impact and allow enough time for implementation and recovery. Emergency change approval is for urgent unplanned changes, separation of duties prevents conflicting roles, and least privilege limits access rights.

Question 10: Option C — Conduct a post-implementation review and document lessons learned.
After a failed change, a post-implementation review helps identify root cause, update procedures, and document lessons learned for future changes. Simply reapplying, closing the ticket, or transferring the request without follow-up misses the opportunity to improve change management.